

IT SECURITY POLICY

IT SECURITY POLICY - XYZ Corp

1. Password Policy

Min 12 chars, 1 uppercase, 1 lowercase, 1 number, 1 special. Change every 90 days. No reuse of last 5 passwords. MFA mandatory for email, HRMS, AWS, VPN.

2. VPN

Must use company VPN (Pritunl) for accessing production, client data when remote. VPN logs monitored.

3. Device Security

Laptop full disk encryption enabled. Auto-lock after 5 mins idle. No USB without IT approval. Antivirus mandatory (CrowdStrike).

4. Data Classification

Public, Internal, Confidential, Restricted. Client data = Confidential minimum. Restricted data cannot be shared outside.

5. Email Security

No forwarding official mail to personal Gmail. Phishing report button to be used. Monthly phishing simulation.

6. Access Control

Least privilege principle. Access to prod needs manager + CTO approval via Jira ticket. Access revoked within 24 hrs of exit.

7. Cloud Security

AWS root account MFA mandatory. No public S3 buckets. No hardcoding secrets in code - use AWS Secrets Manager.

8. Incident Reporting

Any suspected breach report to security@xyzcorp.com within 1 hour. Do not try to fix yourself if ransomware.

9. Backup

Code in GitHub, daily backup. No code on local only.

10. Clean Desk

Lock laptop when away. No passwords on sticky notes.

11. Personal Devices

BYOD allowed only for email with MDM. No client data on personal device.

12. Violation

Violation leads to warning or termination depending on impact.